

ISYS90090 · CYBERSECURITY MANAGEMENT

Risk Management

Deciding what to protect, what could go wrong,
and what to do about it.

Week 6 · Atif Ahmad · University of Melbourne



This Week in Cybersecurity Management

01

Study Canvas
Module A

02

Prescribed
reading:
Chapter 4 “Risk
Management”,
pp. 121 to 175

03

OPTIONAL

Answer
discussion
questions on
Canvas, and
chat with peers

04

Attend
workshop

05

OPTIONAL

Continue
discussion with
peers on
Canvas

This week's workshop

PART A

Quiz

PART B

Q&A session on
this week's
content

PART C

Teaching case:
Horizon Scenes
12

Intended Learning Objectives

01

Understand the purpose, role and real-world drivers of the Information Security Risk Management process

02

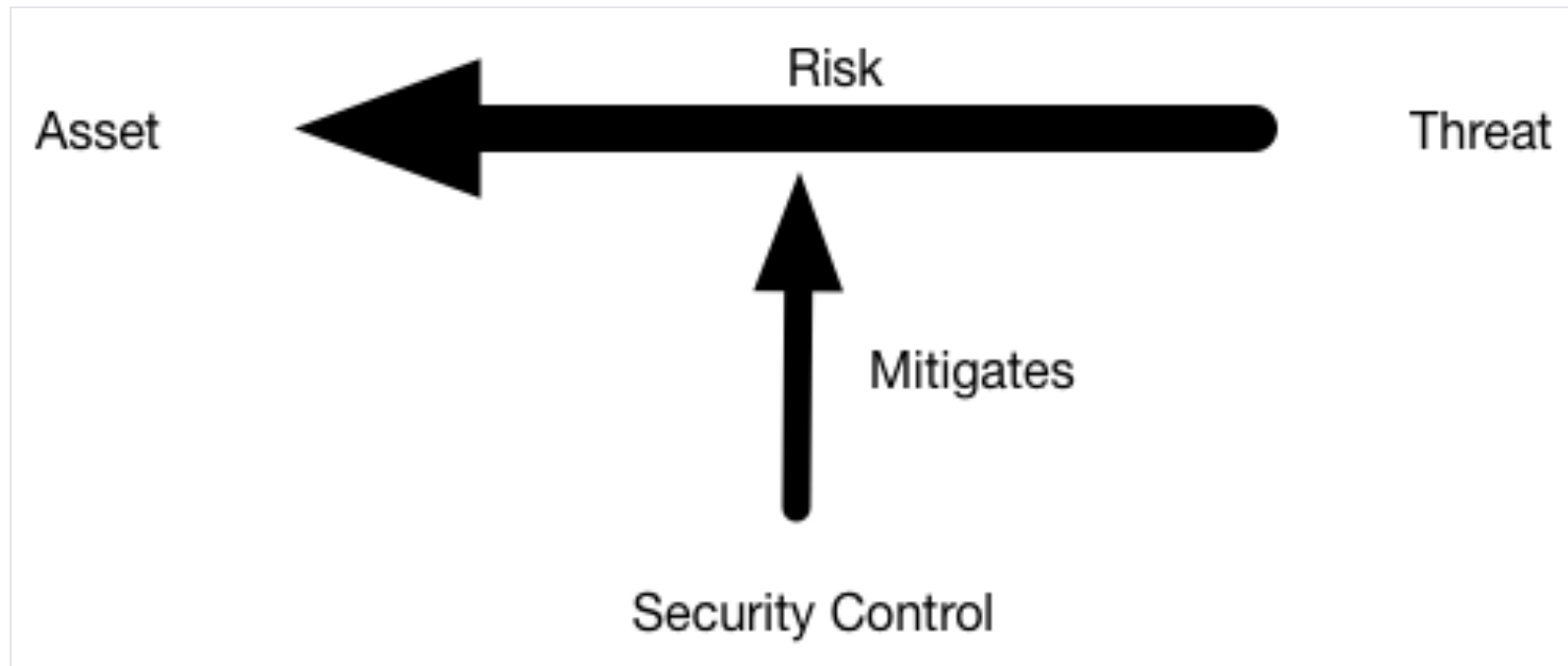
Identify and describe key phases in the Information Security Risk Management process

03

Identify the key deficiencies in the practical application of the Information Security Risk Management process in organisations

THE CORE SCAFFOLD

It all starts from the Triplet Model



Asset ← Risk ← Threat, with the security control mitigating the risk.

Risk Management Process

Risk identification

Context establishment what is the scope of the problem?

Identification of assets what am I trying to protect?

Valuation of assets how to prioritise which assets are more important?

Scenario development what scenarios might impact my assets negatively?

Risk assessment

Consequence how much will it hurt me if this scenario occurs?

Likelihood how likely is this scenario to happen?

Prioritisation what are my priorities when it comes to scenarios?

Risk control

Control strategy selection what is my approach to controlling this scenario?

Control selection what tools do I have at my disposal?

Implementation apply the tools.

Maintenance

Review how are the scenarios changing? The process runs continuously, not once.

Risk Identification



Sensitive Information / Knowledge

IT OPERATIONS

Authentication and Access Control

Passwords, access keys, certificates, security tokens, biometrics, network configurations, firewall configurations, VPN configurations, intrusion detection system (IDS) configurations, access logs

Systems and Data

Source code, system configurations, database backups, data schemas, encryption keys, vulnerability assessments, penetration test results, incident response plans

Hardware

Server configurations, network diagrams, hardware inventory, data centre locations

BUSINESS OPERATIONS

Customer Information

Personally Identifiable Information (PII), contact information, purchase history, financial information, customer lists, customer feedback

Financial Information

Financial statements, budgets, forecasts, pricing information, contracts, invoices, payment information, tax information

Intellectual Property

Trade secrets, patents, trademarks, copyrights, research and development (R&D) data, marketing plans, product roadmaps

Employee Information

Personally Identifiable Information (PII), contact information, salary information, performance reviews, disciplinary actions, medical information

Sensitive Information (2)

LEGAL

Confidential Information

Legal professional privilege, confidential contracts, litigation documents, settlement agreements, non-disclosure agreements (NDAs), internal investigations, whistleblower complaints

Regulatory Compliance

Compliance reports, audit reports, risk assessments, data protection impact assessments (DPIAs), incident reports

HUMAN RESOURCES

Employee Records

Personally Identifiable Information (PII), contact information, salary information, performance reviews, disciplinary actions, medical information, resumes, background checks

Recruitment Information

Candidate information, interview notes, hiring decisions

ADDITIONAL CATEGORIES

Physical Security

Security camera footage, access control logs, building blueprints

Third-Party Information

Vendor contracts, supplier information, partner agreements

Inventory of Assets

System Name: <u>SLS E-Commerce</u>		
Date Evaluated: <u>February 2003</u>		
Evaluated By: <u>D. Jones</u>		
Information assets	Data classification	Impact to profitability
Information Transmitted:		
EDI Document Set 1 —Logistics BOL to outsourcer (outbound)	Confidential	High
EDI Document Set 2—Supplier orders (Outbound)	Confidential	High
EDI Document Set 2—Supplier fulfillment advice (inbound)	Confidential	Medium
Customer order via SSL (inbound)	Confidential	Critical
Customer service Request via e-mail (inbound)	Private	Medium
DMZ Assets:		
Edge Router	Public	Critical
Web server #1—home page and core site	Public	Critical
Web server #2—Application server	Private	Critical

Notes: BOL: Bill of Lading;
 DMZ: Demilitarized Zone
 EDI: Electronic Data Interchange
 SSL: Secure Sockets Layer

FIGURE 4-3 Example Worksheet for the Asset Identification of Information Systems

Source: Whitman & Mattord, Chapter 4 (Figure 4-3).

Start with this asset?

The worksheet is a container, not the thing itself. Ask which of these entries is the asset you actually care about — and where else that same information already lives.

There are different types of impact

TABLE 4-2 Example of a Weighted Factor Analysis Worksheet

Information asset	Criteria 1: impact to revenue	Criteria 2: impact to profitability	Criteria 3: public image impact	Weighted score
<i>Criterion Weight (1-100) Must total 100</i>	30	40	30	
EDI Document Set 1— Logistics BOL to outsourcer (outbound)	0.8	0.9	0.5	75
EDI Document Set 2— Supplier orders (outbound)	0.8	0.9	0.6	78
EDI Document Set 2— Supplier fulfillment advice (inbound)	0.4	0.5	0.3	41
Customer order via SSL (inbound)	1.0	1.0	1.0	100
Customer service request via e-mail (inbound)	0.4	0.4	0.9	55
Notes: EDI: Electronic Data Interchange SSL: Secure Sockets Layer				

Source: Whitman & Mattord, Chapter 4 (Table 4-2) — weighted factor analysis worksheet.

Risk Assessment: Likelihood

Can be calculated from several sources, including:

Past records

Experience

Simulations

Experimentation

Specialist and
expert
judgements

Risk Assessment: Impact

Cost depends on the scenario,
not the asset.

The cost of a confidentiality attack on a document asset is different to the cost of an availability attack on that same document.

Impact is measured in dollars and cents.

MULTIPLE AVENUES OF IMPACT

Direct cost

in dollars and cents

Productivity cost

in regaining the asset or the organisation's reputation

Penalties

for example, if confidentiality has been breached

Risk Assessment Matrix

		Severity →				
		Negligible	Minor	Moderate	Significant	Severe
Likelihood ↑	Very Likely	Low Med	Medium	Med Hi	High	High
	Likely	Low	Low Med	Medium	Med Hi	High
	Possible	Low	Low Med	Medium	Med Hi	Med Hi
	Unlikely	Low	Low Med	Low Med	Medium	Med Hi
	Very Unlikely	Low	Low	Low Med	Medium	Medium

Risk Matrix Example

Likelihood X Severity = Risk Level

Source: RiskPal (<https://riskpal.com/risk-assessment-matrices/>). Likelihood × severity = risk level.

Risk Control Strategies

Once we know the risks for each asset, we can choose one of four strategies to control each risk:

AVOIDANCE

Prevent by
applying
safeguards

TRANSFERENCE

Transfer the risk

MITIGATION

Reduce impact by
Incident
Response

ACCEPTANCE

Understand
consequences
and accept risk

Key OCTAVE-S Artifact

Human Actors Using Network Access

RISK ASSESSMENT · A
WORKED ARTIFACT

Asset	Access	Actor	Motive	Outcome	Impact Value							Probability		Practice Areas															Approach		
					Reputation	Financial	Productivity	Fines	Safety	Other	Value	Confidence	1. Sec Training	6. Cont Planning	7. Phys Acc Cntrl	8. Monitor Phys Sec	9. Sys & Net Mgmt	10. Monitor I T Sec	11. Authen & Auth	12. Vul Mgmt	13. Encryption	14. Sec Arch & Des	15. Incident Mgmt	2. Sec Strategy	3. Sec Mgmt	4. Sec Policy & Reg	5. Coll Sec Mgmt	Accept	Defer	Mitigate	
CRM System	network	inside	accidental	disclosure								— — —																			
				modification	M	M	M	—	—	M	M	X — —	Y	R				Y	G	Y	R	R	Y	G				Y	Y	R	G
				loss, destruction	M	L	M	—	—	M	M	X — —	Y	R				Y	G	Y	R	R	Y	G				Y	Y	R	G
			deliberate	disclosure	H	H	H	H	—	H	L	— — X	Y	R				Y	G	Y	R	R	Y	G				Y	Y	R	G
				modification	H	H	M	—	—	M	L	— — X	Y	R				Y	G	Y	R	R	Y	G				Y	Y	R	G
				loss, destruction	H	H	M	—	—	M	L	— — X	Y	R				Y	G	Y	R	R	Y	G				Y	Y	R	G
		outside	accidental	disclosure								— — —																			
				modification								— — —																			
				loss, destruction	M	M	M	—	—	M	L	X — —	Y	R				Y	G	Y	R	R	Y	G				Y	Y	R	G
			deliberate	disclosure	H	H	L	—	—	M	L	— — X	Y	R				Y	G	Y	R	R	Y	G				Y	Y	R	G
				modification	H	H	M	—	—	M	L	— — X	Y	R				Y	G	Y	R	R	Y	G				Y	Y	R	G
				loss, destruction	H	H	M	—	—	M	L	— — X	Y	R				Y	G	Y	R	R	Y	G				Y	Y	R	G
CRM System	network	inside	accidental	disclosure							— — —																				
				modification								— — —																			
				loss, destruction	M	M	M	—	—	M	L	X — —	Y	R				Y	G	Y	R	R	Y	G				Y	Y	R	G
			deliberate	disclosure	H	H	H	H	—	H	L	— — X	Y	R				Y	G	Y	R	R	Y	G				Y	Y	R	G
				modification	H	H	M	—	—	M	L	— — X	Y	R				Y	G	Y	R	R	Y	G				Y	Y	R	G
				loss, destruction	H	H	M	—	—	M	L	— — X	Y	R				Y	G	Y	R	R	Y	G				Y	Y	R	G
		outside	accidental	disclosure								— — —																			
				modification								— — —																			
				loss, destruction	M	M	M	—	—	M	L	X — —	Y	R				Y	G	Y	R	R	Y	G				Y	Y	R	G
			deliberate	disclosure	H	H	L	—	—	M	L	— — X	Y	R				Y	G	Y	R	R	Y	G				Y	Y	R	G
				modification	H	H	M	—	—	M	L	— — X	Y	R				Y	G	Y	R	R	Y	G				Y	Y	R	G
				loss, destruction	H	H	M	—	—	M	L	— — X	Y	R				Y	G	Y	R	R	Y	G				Y	Y	R	G

Source: Carnegie Mellon Software Engineering Institute — OCTAVE-S

SY 59019 - Cyber Security Management

Deficiencies in the Practice of Risk Management

DEFICIENCY 1

Information security risk identification is commonly perfunctory

DEFICIENCY 2

Information security risks are commonly estimated with little reference to the organization's actual situation

DEFICIENCY 3

Information security risk assessment is commonly performed on an intermittent, non-historical basis

DISCUSSION

Analyse this!

According to an old story, a lord of ancient China once asked his physician, a member of a family of healers, which of them was most skilled in the art.

“My eldest brother sees the spirit of sickness and removes it before it takes shape, so his name does not get out of the house. My elder brother cures sickness when it is still extremely minute, so his name does not get out of the neighbourhood. As for me, I puncture veins, prescribe potions, and massage skin, so from time to time my name gets out and is heard among the lords.”

THE PHYSICIAN, WHOSE NAME BECAME SYNONYMOUS WITH MEDICAL SCIENCE IN CHINA (third century BCE)

QUESTIONS

1. Which of the brothers is most risk-aware? Which is least risk-aware? And which is the most successful risk manager? Justify your answer.
2. What lessons can one draw from this story?

Q&A

Questions on risk management — and on where the process breaks down in practice.

ISYS90090 · Cybersecurity Management · Week 6

